

Audit npm — politique et allowlist

Commandes

Commande	Usage
<code>npm run audit:prod</code>	Audit production (utilisé en CI)
<code>npm audit</code>	Rapport complet (dev inclus)

Règles CI

1. **Critical** sur dépendances prod (`--omit=dev`) → **bloquant**, sans exception.
2. **High** sur dépendances prod → bloquant sauf packages listés dans `security/audit-allowlist.json`.
3. Rapport hebdomadaire : workflow **Audit npm planifié** (lundi 6h UTC).

Allowlist actuelle

Package	Motif
<code>react-simple-maps</code> (+ chaîne d3)	Cartographie ; correctif = downgrade majeur ; usage client interne

Fichier : [security/audit-allowlist.json](#)

Pour ajouter une entrée : documenter le **motif métier** et la **date de revue** dans une PR.

Actions correctives

```
npm audit fix          # correctifs sans breaking change  
npm audit fix --force  # uniquement après revue (risque régression)
```

Après `npm audit fix`, relancer `npm run audit:prod` et mettre à jour l'allowlist si des CVE disparaissent.